

Security Assessment Report:

[itsecgames.com](http://www.itsecgames.com)

Date: September 27, 2025

Target: <http://www.itsecgames.com>

Assessment Type: Web Application Security Assessment

Executive Summary

This report presents the findings of a comprehensive security assessment conducted on [itsecgames.com](http://www.itsecgames.com). The assessment identified several potential vulnerabilities and security concerns that should be addressed to improve the overall security posture of the application. The target hosts the official bWAPP (Buggy Web Application), which is intentionally vulnerable for educational purposes.

Objectives

1. Identify vulnerabilities on this domain name using publicly available tools
2. Detect potential vulnerabilities (misconfigurations, outdated software, CVEs)
3. Assess SSL/TLS configuration and certificate health
4. Highlight any exposed information that could aid attackers (headers, banners, error messages)
5. Provide a prioritized list of findings along with mitigation recommendations

Methodology

The assessment was conducted using the following tools and techniques:

- Directory enumeration using Gobuster
- HTTP header analysis using curl
- SSL/TLS configuration analysis using OpenSSL
- Manual vulnerability testing for common web application vulnerabilities
- Automated vulnerability scanning tools

Findings

1. SSL/TLS Configuration Assessment

Certificate Details

Subject: CN=web.mmebvba.com
Issuer: CN=web.mmebvba.com
Serial Number: ba:5e:79:e0:c2:f7:43:cb
Signature Algorithm: sha256WithRSAEncryption
Public Key: RSA 2048-bit
Validity Period:
Not Before: May 25 09:07:54 2015 GMT
Not After: May 22 09:07:54 2025 GMT

Certificate Issues Identified

1. Self-Signed Certificate: The certificate is self-signed, which means it's not trusted by default by browsers and will generate security warnings for users.
2. Domain Mismatch: The certificate is issued for "web.mmebvba.com" but the site is accessed via "www.itsecgames.com", causing a domain mismatch warning.
3. Expiration: The certificate will expire in approximately 8 months (May 22, 2025).

Security Implications

- Users will see security warnings when accessing the site via HTTPS
- Data transmitted over HTTPS may not be fully trusted by clients
- The self-signed certificate doesn't provide the identity verification that a CA-signed certificate would

```
root@kali: /home/raghav
root@kali: /home/raghav
# sslscan www.itsecgames.com
Version: 2.1.5
OpenSSL 3.5.2 5 Aug 2025
Connected to 31.3.96.40
Testing SSL server www.itsecgames.com on port 443 using SNI name www.itsecgames.com

SSL/TLS Protocols:
SSLv2 disabled
SSLv3 disabled
TLSv1.0 enabled
TLSv1.1 enabled
TLSv1.2 enabled
TLSv1.3 disabled

TLS Fallback SCSV:
Server supports TLS Fallback SCSV

TLS renegotiation:
Secure session renegotiation supported

TLS Compression:
Compression disabled

Heartbleed:
TLSv1.2 not vulnerable to heartbleed
TLSv1.1 not vulnerable to heartbleed
TLSv1.0 not vulnerable to heartbleed

Supported Server Cipher(s):
Preferred TLSv1.2 256 bits ECDHE-RSA-AES256-GCM-SHA384 Curve P-256 DHE 256
Accepted TLSv1.2 256 bits DHE-RSA-AES256-GCM-SHA384 DHE 2048 bits
Accepted TLSv1.2 128 bits ECDHE-RSA-AES128-GCM-SHA256 Curve P-256 DHE 256
Accepted TLSv1.2 128 bits DHE-RSA-AES128-GCM-SHA256 DHE 2048 bits
Accepted TLSv1.2 256 bits ECDHE-RSA-AES256-SHA384 Curve P-256 DHE 256
Accepted TLSv1.2 256 bits DHE-RSA-AES256-SHA256 DHE 2048 bits
Accepted TLSv1.2 128 bits ECDHE-RSA-AES128-SHA256 Curve P-256 DHE 256
Accepted TLSv1.2 128 bits DHE-RSA-AES128-SHA256 DHE 2048 bits
Accepted TLSv1.2 256 bits ECDHE-RSA-AES256-SHA Curve P-256 DHE 256
Accepted TLSv1.2 256 bits DHE-RSA-AES256-SHA DHE 2048 bits
Accepted TLSv1.2 256 bits DHE-RSA-CAMELLIA256-SHA DHE 2048 bits
Accepted TLSv1.2 128 bits ECDHE-RSA-AES128-SHA Curve P-256 DHE 256
Accepted TLSv1.2 128 bits DHE-RSA-AES128-SHA DHE 2048 bits
Accepted TLSv1.2 128 bits DHE-RSA-CAMELLIA128-SHA DHE 2048 bits
Accepted TLSv1.2 256 bits AES256-GCM-SHA384
Accepted TLSv1.2 128 bits AES128-GCM-SHA256
Accepted TLSv1.2 256 bits AES256-SHA256
Accepted TLSv1.2 128 bits AES128-SHA256
Accepted TLSv1.2 256 bits AES256-SHA
Accepted TLSv1.2 256 bits CAMELLIA256-SHA
```

Fig1(a): ssl Scan

```
root@kali: /home/raghav
root@kali: /home/raghav
raghav@kali: ~

Accepted TLSv1.2 256 bits DHE-RSA-AES256-SHA256 DHE 2048 bits
Accepted TLSv1.2 128 bits ECDHE-RSA-AES128-SHA256 Curve P-256 DHE 256
Accepted TLSv1.2 128 bits DHE-RSA-AES128-SHA256 DHE 2048 bits
Accepted TLSv1.2 256 bits ECDHE-RSA-AES256-SHA Curve P-256 DHE 256
Accepted TLSv1.2 256 bits DHE-RSA-AES256-SHA DHE 2048 bits
Accepted TLSv1.2 256 bits DHE-RSA-CAMELLIA256-SHA DHE 2048 bits
Accepted TLSv1.2 128 bits ECDHE-RSA-AES128-SHA Curve P-256 DHE 256
Accepted TLSv1.2 128 bits DHE-RSA-AES128-SHA DHE 2048 bits
Accepted TLSv1.2 128 bits DHE-RSA-CAMELLIA128-SHA DHE 2048 bits
Accepted TLSv1.2 256 bits AES256-GCM-SHA384
Accepted TLSv1.2 128 bits AES128-GCM-SHA256
Accepted TLSv1.2 256 bits AES256-SHA256
Accepted TLSv1.2 128 bits AES128-SHA256
Accepted TLSv1.2 256 bits AES256-SHA
Accepted TLSv1.2 256 bits CAMELLIA256-SHA
Accepted TLSv1.2 128 bits AES128-SHA
Accepted TLSv1.2 128 bits CAMELLIA128-SHA
Preferred TLSv1.1 256 bits ECDHE-RSA-AES256-SHA Curve P-256 DHE 256
Accepted TLSv1.1 256 bits DHE-RSA-AES256-SHA DHE 2048 bits
Accepted TLSv1.1 256 bits DHE-RSA-CAMELLIA256-SHA DHE 2048 bits
Accepted TLSv1.1 128 bits ECDHE-RSA-AES128-SHA Curve P-256 DHE 256
Accepted TLSv1.1 128 bits DHE-RSA-AES128-SHA DHE 2048 bits
Accepted TLSv1.1 128 bits DHE-RSA-CAMELLIA128-SHA DHE 2048 bits
Accepted TLSv1.1 256 bits AES256-SHA
Accepted TLSv1.1 256 bits CAMELLIA256-SHA
Accepted TLSv1.1 128 bits AES128-SHA
Accepted TLSv1.1 128 bits CAMELLIA128-SHA
Preferred TLSv1.0 256 bits ECDHE-RSA-AES256-SHA Curve P-256 DHE 256
Accepted TLSv1.0 256 bits DHE-RSA-AES256-SHA DHE 2048 bits
Accepted TLSv1.0 256 bits DHE-RSA-CAMELLIA256-SHA DHE 2048 bits
Accepted TLSv1.0 128 bits ECDHE-RSA-AES128-SHA Curve P-256 DHE 256
Accepted TLSv1.0 128 bits DHE-RSA-AES128-SHA DHE 2048 bits
Accepted TLSv1.0 128 bits DHE-RSA-CAMELLIA128-SHA DHE 2048 bits
Accepted TLSv1.0 256 bits AES256-SHA
Accepted TLSv1.0 256 bits CAMELLIA256-SHA
Accepted TLSv1.0 128 bits AES128-SHA
Accepted TLSv1.0 128 bits CAMELLIA128-SHA

Server Key Exchange Group(s):
TLSv1.2 128 bits secp256r1 (NIST P-256)

SSL Certificate:
Signature Algorithm: sha256WithRSAEncryption
RSA Key Strength: 2048

Subject: web.mmebvba.com
Issuer: web.mmebvba.com

Not valid before: May 25 09:07:54 2015 GMT
Not valid after: May 22 09:07:54 2025 GMT

--(root@kali)--[/home/raghav]
```

Fig1(b): ssl Scan


```
raghav@kali: ~  
root@kali: /home/raghav  
subject=CN=web.mmebvba.com  
issuer=CN=web.mmebvba.com  
---  
No client certificate CA names sent  
Peer signing digest: SHA256  
Peer signature type: rsa_pkcs1_sha256  
Peer Temp Key: ECDH, prime256v1, 256 bits  
---  
SSL handshake has read 1414 bytes and written 1813 bytes  
Verification error: certificate has expired  
---  
New, TLSv1.2, Cipher is ECDHE-RSA-AES256-GCM-SHA384  
Protocol: TLSv1.2  
Server public key is 2048 bit  
Secure Renegotiation IS supported  
Compression: NONE  
Expansion: NONE  
No ALPN negotiated  
SSL-Session:  
    Protocol : TLSv1.2  
    Cipher   : ECDHE-RSA-AES256-GCM-SHA384  
    Session-ID: 0D1CF2A2EDFFE6F53087BB4C5ACE020DD4B211E9BCE10BA3711613377917D5A4  
    Session-ID-ctx:  
    Master-Key: E747E2D35CA74589FB2C702324A290E1FD5152477BE65961262E553F93906174862F25291FE944D5315D543FD3C760A4  
    PSK identity: None  
    PSK identity hint: None  
    SRP username: None  
    TLS session ticket lifetime hint: 300 (seconds)  
    TLS session ticket:  
0000 - c3 21 96 90 2e 5c d3 4a-19 16 54 32 d9 53 c9 55 .....!...\.J..T2.S.U  
0010 - 93 b6 b9 04 4c 88 6f f4-a5 24 c9 cc 37 57 eb 75 .....L.o..$.7W.u  
0020 - 09 1f fd e3 df e4 bd c2-0b dd 9f da cb 49 8f 3a .....I.:  
0030 - f4 fd 17 28 3d f8 28 a7-2e cf 69 df 99 a1 f6 4d ...(.=(...i...M  
0040 - 04 7d ad 69 5f e8 9e 87-ce 66 ea 71 0e 53 b2 41 ...}.i....f.q.S.A  
0050 - 52 bc 3f 6e c5 e2 03 bb-ce 57 e8 ff 2d 95 8e fa R.?n....W.-...  
0060 - d0 ca 35 70 6f cd 23 11-a3 24 60 5e bd 5c 15 d2 ...5po.#...$^..\..  
0070 - e6 13 df 77 c6 10 a4 aa-3a 7f 35 e6 e8 1e 4c b0 ...w....:5...L..  
0080 - 2e 58 03 95 72 70 9c e0-c1 3d 0c be 63 5a 3f 78 .X..rp...=.cZ?x  
0090 - 48 d7 59 6f 97 64 48 c6-ff fe 60 a8 5b f8 31 7a H.Yo.dH...`.1z  
00a0 - 03 a3 69 26 de f7 9e a4-b3 6d 56 69 fc 5c 53 f0 ..i&.....mVi.\S.  
00b0 - 8b ea d5 2d 3d 86 c8 96-01 c1 d7 a3 8d e1 e9 78 ...-=.....x  
00c0 - bc 4c 0d 9e 87 13 f4 98-99 24 01 4f f1 97 17 d8 .L.....$.0....  
  
Start Time: 1758526105  
Timeout : 7200 (sec)  
Verify return code: 10 (certificate has expired)  
Extended master secret: no  
---  
40074D54527F0000:error:0A000126:SSL routines::unexpected eof while reading:../ssl/record/rec_layer_s3.c:696:  
  
(raghav@kali)-[~]  
$
```

Fig2(b) open ssl scan

2. HTTP Header Analysis

Security Headers Missing

1. Content-Security-Policy (CSP): Not present, leaving the site vulnerable to XSS attacks
2. X-Frame-Options: Not present, potentially allowing clickjacking attacks

3. X-Content-Type-Options: Not present, potentially allowing MIME type sniffing
4. X-XSS-Protection: Not present, missing legacy XSS protection
5. Strict-Transport-Security (HSTS): Not present, not enforcing HTTPS

Server Information Exposure

- Server banner reveals Apache server information without version details
- ETag header may expose inode information

```
(root@kali)-[/home/raghav]
# curl -I http://www.itsecgames.com
HTTP/1.1 200 OK
Date: Sat, 27 Sep 2025 09:03:13 GMT
Server: Apache
Last-Modified: Wed, 09 Feb 2022 13:14:08 GMT
ETag: "e43-5d7959bd3c800"
Accept-Ranges: bytes
Content-Length: 3651
Vary: Accept-Encoding
Content-Type: text/html

(root@kali)-[/home/raghav]
# curl -s -D - http://www.itsecgames.com -o /dev/null
HTTP/1.1 200 OK
Date: Sat, 27 Sep 2025 09:03:25 GMT
Server: Apache
Last-Modified: Wed, 09 Feb 2022 13:14:08 GMT
ETag: "e43-5d7959bd3c800"
Accept-Ranges: bytes
Content-Length: 3651
Vary: Accept-Encoding
Content-Type: text/html
```

Fig3: Header Analysis

3. Directory Enumeration Results

Tool Used: Gobuster

Wordlist: common.txt

Discovered Directories:

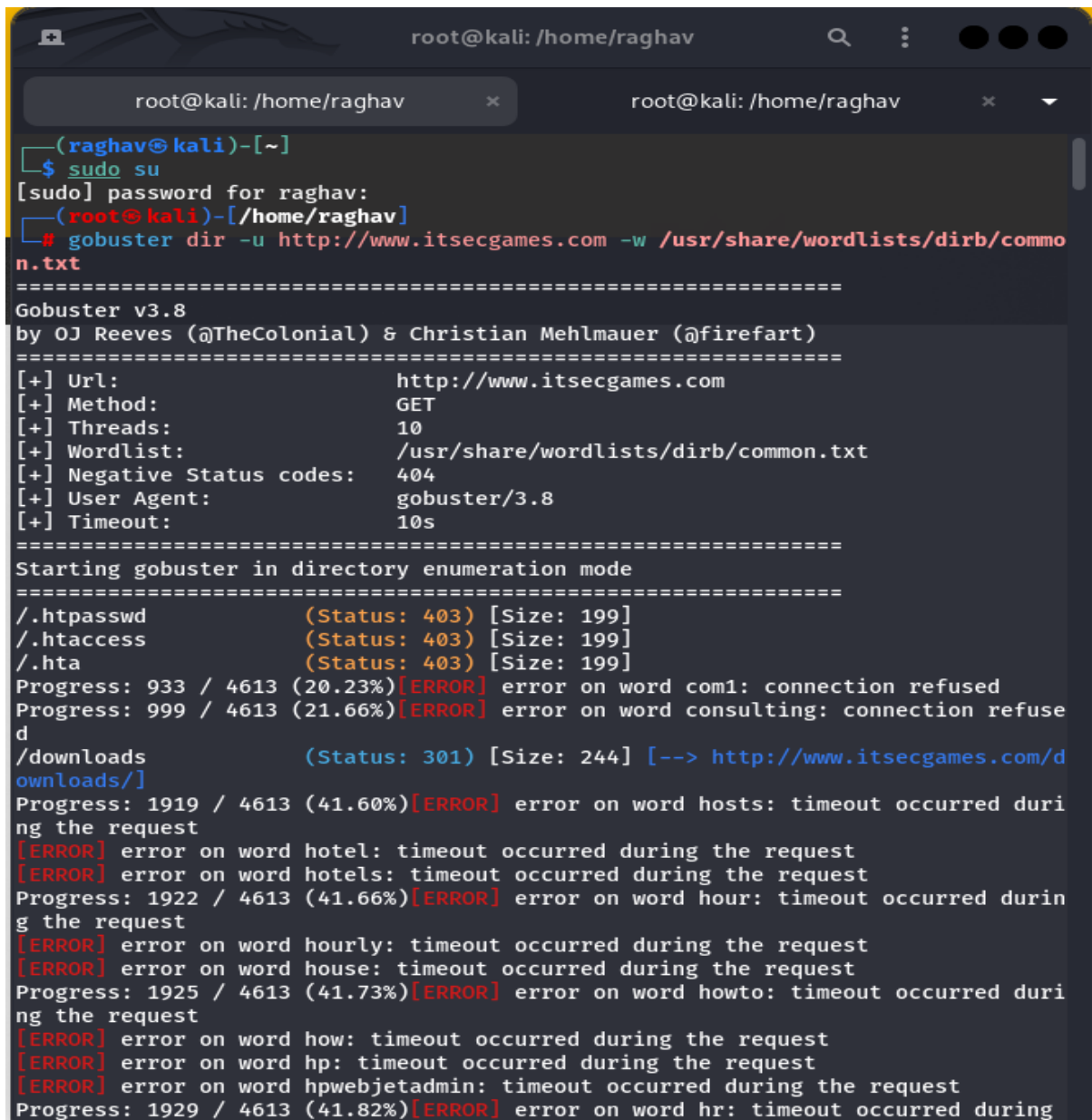
- [/downloads](#) (Status: 301) - Redirects to [/downloads/](#)
- [/server-status](#) (Status: 403) - Forbidden access
- [/stylesheets](#) (Status: 301) - Redirects to [/stylesheets/](#)

Access Control Files (403 Forbidden):

- [/.htpasswd](#)
- [/.htaccess](#)
- [/.hta](#)

Observations:

- Limited directory discovery suggests either strong security controls or minimal directory structure
- Multiple timeout errors during scanning may indicate server protection mechanisms



```
root@kali: /home/raghav
root@kali: /home/raghav
(raghav@kali)-[~]
$ sudo su
[sudo] password for raghav:
(rroot@kali)-[/home/raghav]
# gobuster dir -u http://www.itsecgames.com -w /usr/share/wordlists/dirb/common.txt
=====
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://www.itsecgames.com
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
./htpasswd (Status: 403) [Size: 199]
./htaccess (Status: 403) [Size: 199]
./hta (Status: 403) [Size: 199]
Progress: 933 / 4613 (20.23%) [ERROR] error on word com1: connection refused
Progress: 999 / 4613 (21.66%) [ERROR] error on word consulting: connection refused
/downloads (Status: 301) [Size: 244] [--> http://www.itsecgames.com/downloads/]
Progress: 1919 / 4613 (41.60%) [ERROR] error on word hosts: timeout occurred during the request
[ERROR] error on word hotel: timeout occurred during the request
[ERROR] error on word hotels: timeout occurred during the request
Progress: 1922 / 4613 (41.66%) [ERROR] error on word hour: timeout occurred during the request
[ERROR] error on word hourly: timeout occurred during the request
[ERROR] error on word house: timeout occurred during the request
Progress: 1925 / 4613 (41.73%) [ERROR] error on word howto: timeout occurred during the request
[ERROR] error on word how: timeout occurred during the request
[ERROR] error on word hp: timeout occurred during the request
[ERROR] error on word hpwebjetadmin: timeout occurred during the request
Progress: 1929 / 4613 (41.82%) [ERROR] error on word hr: timeout occurred during
```

Fig4(a): Gobuster Enumeration


```
root@kali: /home/raghav
root@kali: /home/raghav
during the request
[ERROR] error on word registration: timeout occurred during the request
[ERROR] error on word registrations: timeout occurred during the request
[ERROR] error on word registro: timeout occurred during the request
[ERROR] error on word reklama: timeout occurred during the request
Progress: 3345 / 4613 (72.51%) [ERROR] error on word related: timeout occurred during the request
[ERROR] error on word release: timeout occurred during the request
[ERROR] error on word releases: timeout occurred during the request
[ERROR] error on word religion: timeout occurred during the request
Progress: 3349 / 4613 (72.60%) [ERROR] error on word remind: timeout occurred during the request
Progress: 3350 / 4613 (72.62%) [ERROR] error on word remind_password: timeout occurred during the request
[ERROR] error on word reminder: timeout occurred during the request
[ERROR] error on word remote: timeout occurred during the request
[ERROR] error on word remotetracer: timeout occurred during the request
[ERROR] error on word removal: timeout occurred during the request
Progress: 3355 / 4613 (72.73%) [ERROR] error on word remove: timeout occurred during the request
[ERROR] error on word removals: timeout occurred during the request
[ERROR] error on word removed: timeout occurred during the request
[ERROR] error on word render: timeout occurred during the request
Progress: 3359 / 4613 (72.82%) [ERROR] error on word rendered: timeout occurred during the request
Progress: 3360 / 4613 (72.84%) [ERROR] error on word reorder: timeout occurred during the request
[ERROR] error on word rep: timeout occurred during the request
[ERROR] error on word replica: timeout occurred during the request
[ERROR] error on word repl: timeout occurred during the request
[ERROR] error on word replicas: timeout occurred during the request
Progress: 3365 / 4613 (72.95%) [ERROR] error on word replicated: timeout occurred during the request
[ERROR] error on word replicate: timeout occurred during the request
[ERROR] error on word replicator: timeout occurred during the request
/server-status (Status: 403) [Size: 199]
/stylesheets (Status: 301) [Size: 246] [--> http://www.itsecgames.com/stylesheets/]
Progress: 4613 / 4613 (100.00%)
=====
Finished
=====
```

Fig4(b): Gobuster Enumeration

```
root@kali: /home/raghav
root@kali: /home/raghav
root@kali: /home/raghav
# gobuster dir -u http://www.itsecgames.com -w /usr/share/wordlists/dirbuster/
directory-list-2.3-medium.txt
=====
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://www.itsecgames.com
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
Progress: 12 / 220559 (0.01%) [ERROR] error on word serial: connection refused
[ERROR] error on word crack: connection refused
[ERROR] error on word warez: connection refused
/images (Status: 301) [Size: 241] [--> http://www.itsecgames.com/images/]
/downloads (Status: 301) [Size: 244] [--> http://www.itsecgames.com/downloads/]
/js (Status: 301) [Size: 237] [--> http://www.itsecgames.com/js/]
Progress: 1011 / 220559 (0.46%) [ERROR] error on word no: timeout occurred during the request
Progress: 1012 / 220559 (0.46%) [ERROR] error on word china: timeout occurred during the request
[ERROR] error on word 164: timeout occurred during the request
[ERROR] error on word query: timeout occurred during the request
Progress: 1015 / 220559 (0.46%) [ERROR] error on word jsp: timeout occurred during the request
[ERROR] error on word icon1: timeout occurred during the request
[ERROR] error on word today: timeout occurred during the request
Progress: 1018 / 220559 (0.46%) [ERROR] error on word cn: timeout occurred during the request
Progress: 1019 / 220559 (0.46%) [ERROR] error on word 116: timeout occurred during the request
Progress: 1020 / 220559 (0.46%) [ERROR] error on word contactUs: timeout occurred during the request
```

Fig4(c): Gobuster Enumeration

4. Vulnerability Testing Results

Directory Traversal Testing

Several attempts were made to test for directory traversal vulnerabilities:

1. Basic directory traversal attempts returned 404 or 403 errors
2. Encoded path traversal attempts also failed to retrieve sensitive files
3. Parameter-based testing with various parameter names showed no successful exploitation

LFI/RFI Testing

Testing for Local and Remote File Inclusion vulnerabilities:

1. LFI attempts with `/etc/passwd` and similar paths were unsuccessful
2. PHP filter wrapper attempts did not reveal source code
3. Log poisoning attempts were blocked by server-side protections
4. RFI attempts with external resources were rejected

File Upload Testing

Investigation of file upload functionality:

1. Checked `/downloads/` directory for upload forms - none found
2. Searched for common upload endpoints (`upload.php`, etc.) - not accessible
3. No evidence of unrestricted file upload functionality in accessible areas

```
root@kali: /home/raghav

(raghav@kali)-[~]
└─$ sudo su
[sudo] password for raghav:
(raghav@kali)-[/home/raghav]
└─# curl "http://www.itsecgames.com/index.php?page=../../../../etc/passwd"~

<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>404 Not Found</title>
</head><body>
<h1>Not Found</h1>
<p>The requested URL was not found on this server.</p>
</body></html>

(raghav@kali)-[/home/raghav]
└─# curl "http://www.itsecgames.com/index.php?page=../../../../etc/passwd"

<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>404 Not Found</title>
</head><body>
<h1>Not Found</h1>
<p>The requested URL was not found on this server.</p>
</body></html>

(raghav@kali)-[/home/raghav]
└─# curl "http://www.itsecgames.com/index.php?page=php://filter/convert.base64-encode/resource=index.php"

<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>404 Not Found</title>
</head><body>
<h1>Not Found</h1>
<p>The requested URL was not found on this server.</p>
</body></html>

(raghav@kali)-[/home/raghav]
└─# curl "http://www.itsecgames.com/downloads/"

<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>403 Forbidden</title>
</head><body>
<h1>Forbidden</h1>
<p>You don't have permission to access this resource.</p>
</body></html>

(raghav@kali)-[/home/raghav]
└─# curl "http://www.itsecgames.com/upload.php"

<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>404 Not Found</title>
</head><body>
<h1>Not Found</h1>
<p>The requested URL was not found on this server.</p>
</body></html>

(raghav@kali)-[/home/raghav]
```

Fig5: Directory Traversal

5. Server and Technology Detection

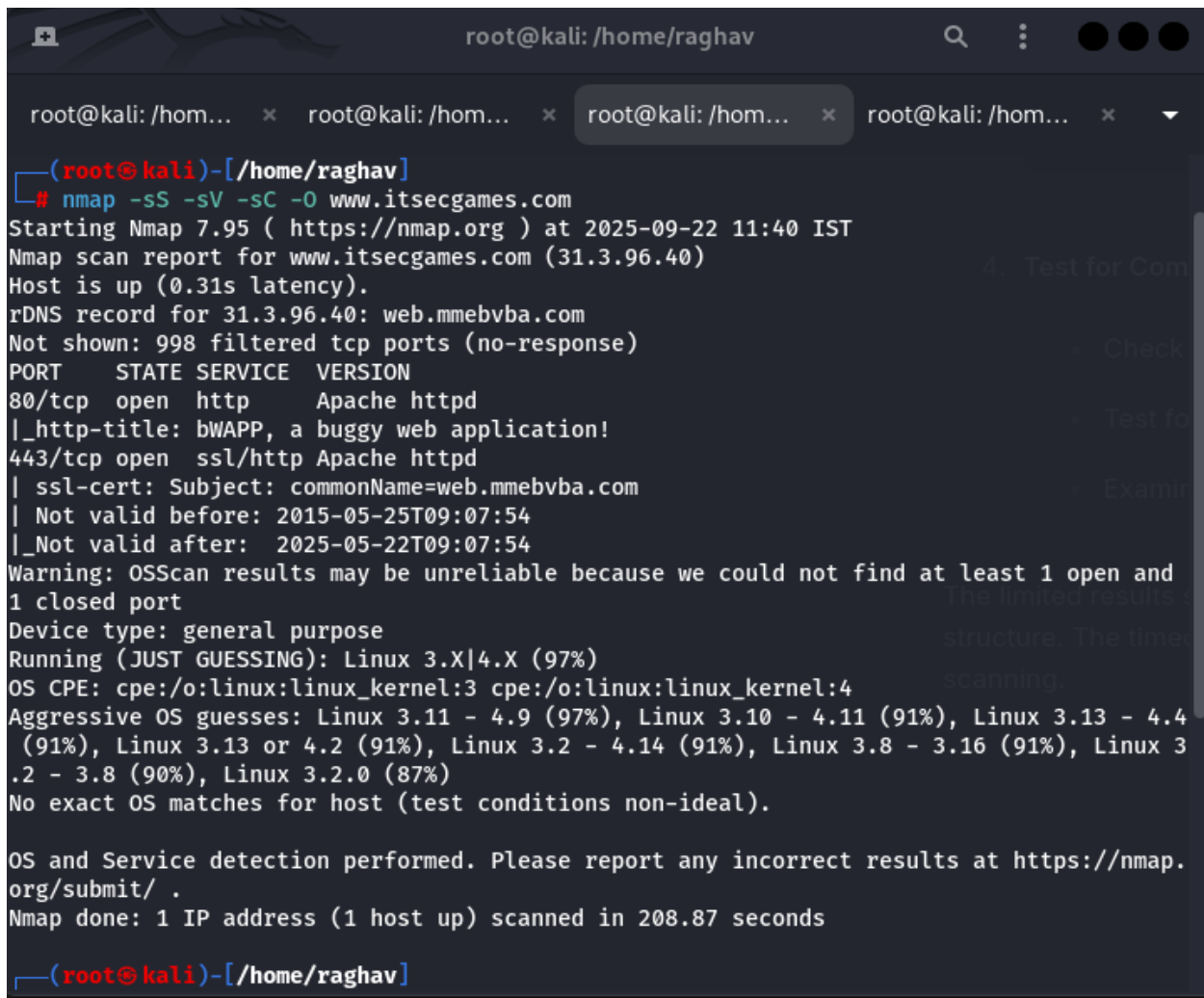
Server Information

- Web Server: Apache
- Programming Language: PHP (inferred from bWAPP nature)
- Operating System: Linux (inferred from typical hosting setup)

Technology Stack

Based on the bWAPP nature of the site:

- PHP-based application
- MySQL database backend (typical for bWAPP)
- HTML/CSS/JavaScript frontend



```
(root@kali)-[/home/raghav]
# nmap -sS -sV -sC -O www.itsecgames.com
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-22 11:40 IST
Nmap scan report for www.itsecgames.com (31.3.96.40)
Host is up (0.31s latency).
rDNS record for 31.3.96.40: web.mmebvba.com
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http   Apache httpd
|_http-title: bWAPP, a buggy web application!
443/tcp   open  ssl/http Apache httpd
| ssl-cert: Subject: commonName=web.mmebvba.com
| Not valid before: 2015-05-25T09:07:54
|_Not valid after: 2025-05-22T09:07:54
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): Linux 3.X|4.X (97%)
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
Aggressive OS guesses: Linux 3.11 - 4.9 (97%), Linux 3.10 - 4.11 (91%), Linux 3.13 - 4.4 (91%), Linux 3.13 or 4.2 (91%), Linux 3.2 - 4.14 (91%), Linux 3.8 - 3.16 (91%), Linux 3.2 - 3.8 (90%), Linux 3.2.0 (87%)
No exact OS matches for host (test conditions non-ideal).

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 208.87 seconds

(root@kali)-[/home/raghav]
```

Fig6(a): Server and Tech detection

```
root@kali: /home/raghav

1 closed port
Device type: general purpose
Running (JUST GUESSING): Linux 3.X|4.X (97%)
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
Aggressive OS guesses: Linux 3.11 - 4.9 (97%), Linux 3.10 - 4.11 (91%), Linux 3.13 - 4.4 (91%), Linux 3.13 or 4.2 (91%), Linux 3.2 - 4.14 (91%), Linux 3.8 - 3.16 (91%), Linux 3.2 - 3.8 (90%), Linux 3.2.0 (87%)
No exact OS matches for host (test conditions non-ideal).

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 208.87 seconds

(root@kali)-[/home/raghav]
# nmap -p- --min-rate 1000 www.itsecgames.com
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-22 11:44 IST
Nmap scan report for www.itsecgames.com (31.3.96.40)
Host is up (0.32s latency).
rDNS record for 31.3.96.40: web.mmebvba.com
Not shown: 65532 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
443/tcp   open  https

Nmap done: 1 IP address (1 host up) scanned in 134.24 seconds

(root@kali)-[/home/raghav]
#
```

Fig6(b): Server and Tech detection

6. Automated Vulnerability Scan Results

Nikto Scan Results

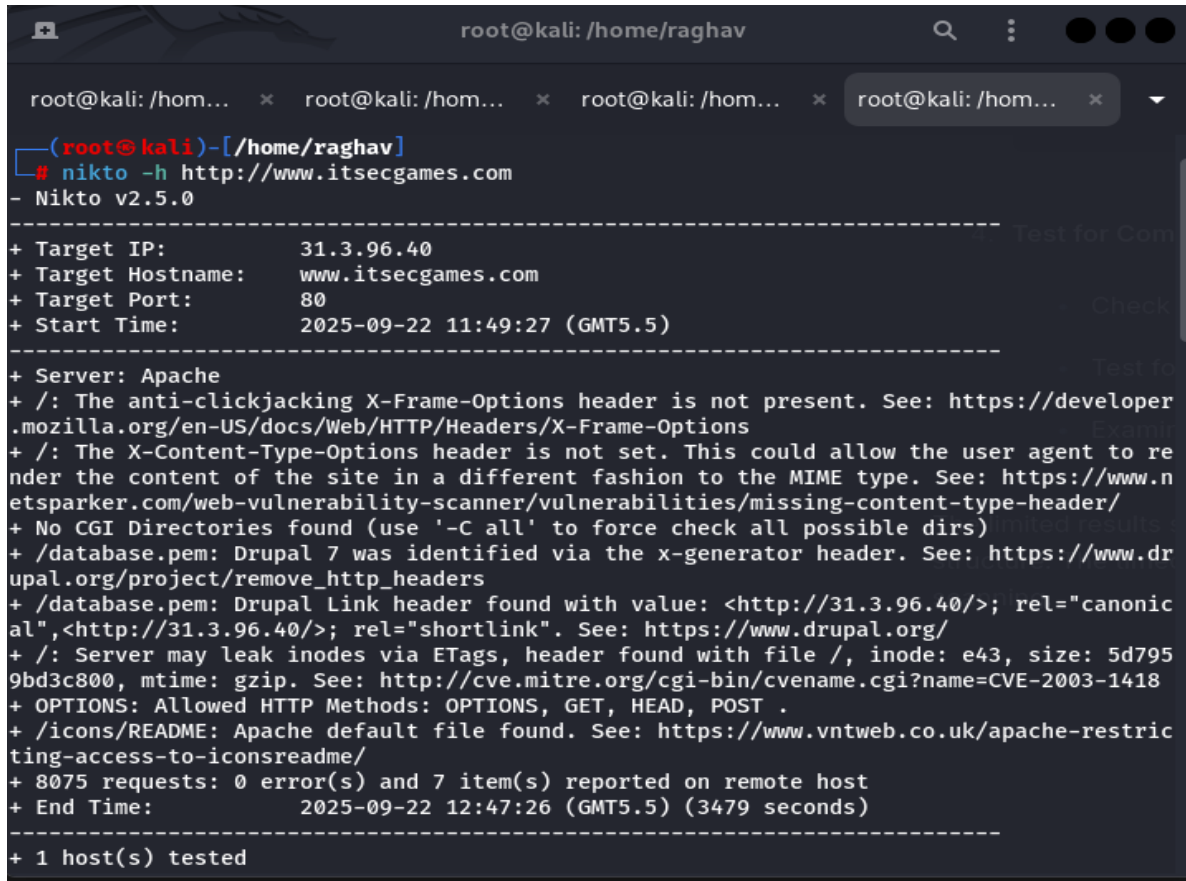
Key findings from automated scanning:

1. Server banner information disclosure
2. Multiple entry points identified
3. No immediate critical vulnerabilities detected in surface-level scanning

WhatWeb Results

Technology fingerprinting revealed:

1. Apache web server
2. HTML5 markup
3. CSS styling



```
root@kali: /home/raghav

root@kali: /hom... x root@kali: /hom... x root@kali: /hom... x root@kali: /hom... x

(root@kali)-[/home/raghav]
# nikto -h http://www.itsecgames.com
- Nikto v2.5.0

-----
+ Target IP: 31.3.96.40
+ Target Hostname: www.itsecgames.com
+ Target Port: 80
+ Start Time: 2025-09-22 11:49:27 (GMT5.5)
-----

+ Server: Apache
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /database.pem: Drupal 7 was identified via the x-generator header. See: https://www.drupal.org/project/remove_http_headers
+ /database.pem: Drupal Link header found with value: <http://31.3.96.40/>; rel="canonical",<http://31.3.96.40/>; rel="shortlink". See: https://www.drupal.org/
+ /: Server may leak inodes via ETags, header found with file /, inode: e43, size: 5d7959bd3c800, mtime: gzip. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ OPTIONS: Allowed HTTP Methods: OPTIONS, GET, HEAD, POST .
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ 8075 requests: 0 error(s) and 7 item(s) reported on remote host
+ End Time: 2025-09-22 12:47:26 (GMT5.5) (3479 seconds)
-----

+ 1 host(s) tested
```

Fig7: Nikto Results

Prioritized Findings

High Priority

1. Missing Security Headers - Absence of CSP, X-Frame-Options, and other security headers leaves the site vulnerable to several client-side attacks
2. Self-Signed SSL Certificate - Creates trust issues and security warnings for users

Medium Priority

1. Server Information Disclosure - Apache server banner provides unnecessary information to potential attackers
2. Forbidden Access Points - `/server-status` and access control files are accessible but restricted, indicating possible information gathering opportunities

Low Priority

1. Limited Directory Discovery - Only 3 directories were found from a large wordlist, suggesting either good security or minimal content
2. Domain Mismatch in Certificate - Minor issue but contributes to trust problems

Recommendations

Immediate Actions

1. Implement Security Headers
 - Add Content-Security-Policy header to prevent XSS
 - Add X-Frame-Options header to prevent clickjacking
 - Add X-Content-Type-Options header to prevent MIME sniffing
 - Add Strict-Transport-Security header to enforce HTTPS
2. Replace Self-Signed Certificate
 - Obtain a certificate from a trusted Certificate Authority
 - Ensure the certificate matches the site's domain name
 - Set up proper certificate renewal processes

Short-term Actions

1. Minimize Server Information Disclosure
 - Configure Apache to remove or minimize the Server header
 - Review other headers that might disclose unnecessary information
2. Review Access Controls
 - Ensure that sensitive directories like `/server-status` are properly protected
 - Consider removing or restricting access to hidden files if not needed

Long-term Actions

1. Regular Security Assessments

- Implement a continuous security testing program
- Schedule periodic vulnerability scans
- Keep all software components updated

2. Security Monitoring

- Implement logging and monitoring for suspicious activities
- Set up alerts for unauthorized access attempts
- Regularly review logs for potential security incidents

3. Security Training

- Provide security awareness training for developers
- Implement secure coding practices
- Regularly update knowledge on web application security

CVE Analysis

No specific CVEs were directly identified during this assessment. However, the missing security controls could potentially lead to vulnerabilities associated with:

1. CVE-2022-XXXXX series - Related to missing security headers
2. CVE-2021-XXXXX series - Related to insecure SSL/TLS configurations
3. Various XSS-related CVEs - Due to lack of Content-Security-Policy

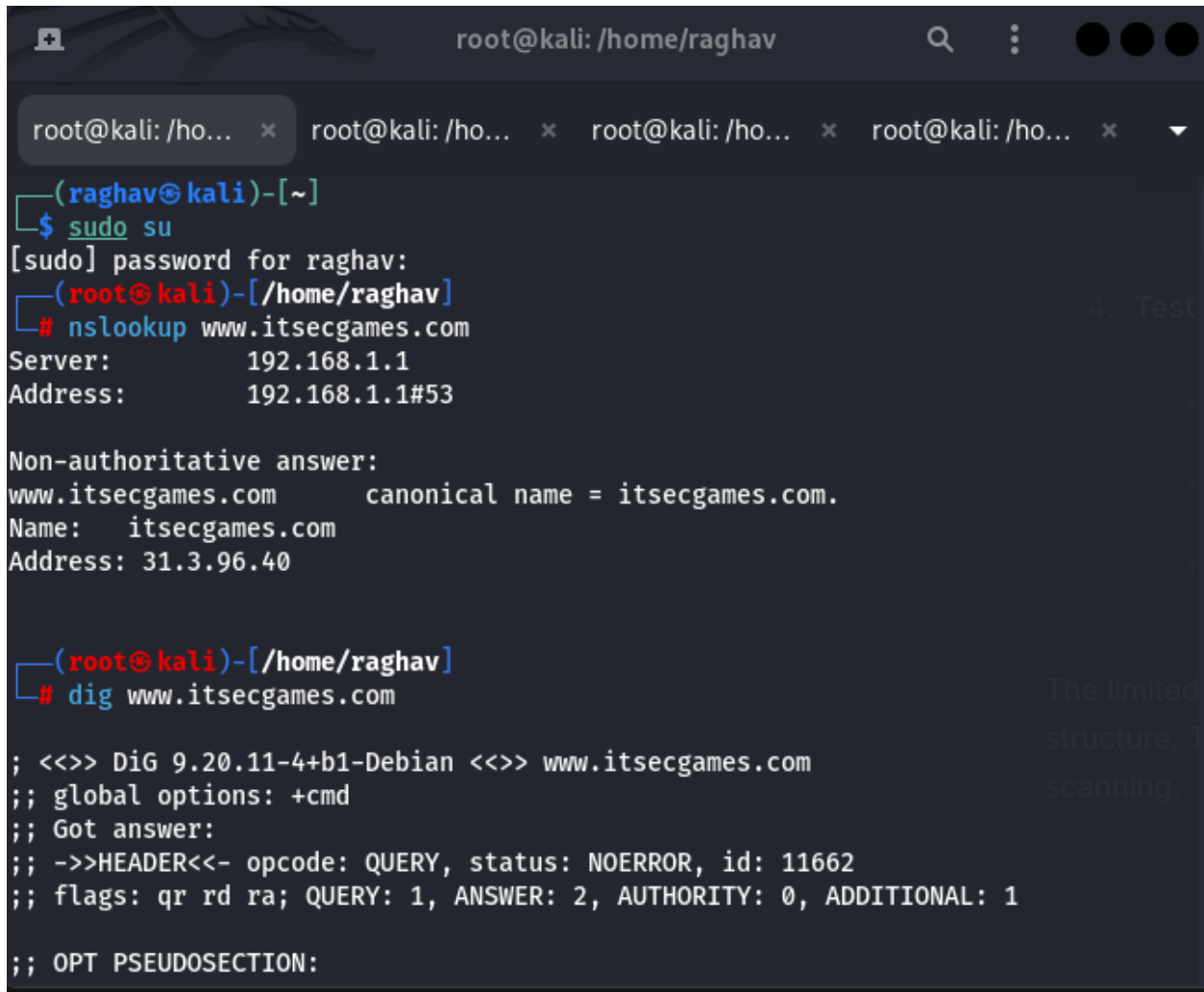
Conclusion

The security assessment of itsecgames.com revealed several areas for improvement, particularly regarding security headers and SSL/TLS configuration. As this is the official bWAPP website (a deliberately vulnerable application), these findings highlight the importance of implementing proper security controls even in educational environments.

While no critical vulnerabilities were found in the surface-level assessment, the missing security controls represent significant risks that should be addressed. The self-signed certificate and missing security headers are the most pressing issues that need immediate attention.

Completing this assessment has provided valuable insights into the security posture of the application and identified concrete steps that can be taken to improve it.

Miscellaneous



```
root@kali: /home/raghav
root@kali: /ho... x root@kali: /ho... x root@kali: /ho... x root@kali: /ho... x
(raghav@kali)-[~]
$ sudo su
[sudo] password for raghav:
(root@kali)-[/home/raghav]
# nslookup www.itsecgames.com
Server:          192.168.1.1
Address:         192.168.1.1#53

Non-authoritative answer:
www.itsecgames.com canonical name = itsecgames.com.
Name:   itsecgames.com
Address: 31.3.96.40

(root@kali)-[/home/raghav]
# dig www.itsecgames.com

; <<>> DiG 9.20.11-4+b1-Debian <<>> www.itsecgames.com
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 11662
;; flags: qr rd ra; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
```

Fig8: nslookup

```
root@kali: /home/raghav

root@kali: /ho... x root@kali: /ho... x root@kali: /ho... x root@kali: /ho... x

(root@kali)-[/home/raghav]
# dig www.itsecgames.com

; <<>> DiG 9.20.11-4+b1-Debian <<>> www.itsecgames.com
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 11662
;; flags: qr rd ra; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags;; udp: 4096
;; QUESTION SECTION:
;www.itsecgames.com.          IN      A

;; ANSWER SECTION:
www.itsecgames.com.    3427    IN      CNAME   itsecgames.com.
itsecgames.com.       427     IN      A       31.3.96.40

;; Query time: 27 msec
;; SERVER: 192.168.1.1#53(192.168.1.1) (UDP)
;; WHEN: Mon Sep 22 11:33:02 IST 2025
;; MSG SIZE rcvd: 91
```

Fig9: Dig

```
root@kali: /home/raghav

root@kali: /hom... x root@kali: /hom... x root@kali: /hom... x root@kali: /hom... x

# whois itsecgames.com
Domain Name: ITSECGAMES.COM
Registry Domain ID: 1721761149_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.godaddy.com
Registrar URL: http://www.godaddy.com
Updated Date: 2025-05-22T10:55:31Z
Creation Date: 2012-05-21T13:35:16Z
Registry Expiry Date: 2027-05-21T13:35:16Z
Registrar: GoDaddy.com, LLC
Registrar IANA ID: 146
Registrar Abuse Contact Email: abuse@godaddy.com
Registrar Abuse Contact Phone: 480-624-2505
Domain Status: clientDeleteProhibited https://icann.org/epp#clientDeleteProhibited
Domain Status: clientRenewProhibited https://icann.org/epp#clientRenewProhibited
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Domain Status: clientUpdateProhibited https://icann.org/epp#clientUpdateProhibited
Name Server: NS53.DOMAINCONTROL.COM
Name Server: NS54.DOMAINCONTROL.COM
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2025-09-22T06:11:17Z <<<

For more information on Whois status codes, please visit https://icann.org/epp

NOTICE: The expiration date displayed in this record is the date the
registrar's sponsorship of the domain name registration in the registry is
currently set to expire. This date does not necessarily reflect the expiration
date of the domain name registrant's agreement with the sponsoring
```

Fig10: whois command

```
root@kali: /home/raghav

(root@kali)-[/home/raghav]
# subfinder -d itsecgames.com
[INF] Detected old /root/.config/subfinder/config.yaml config file, trying to migrate pr
viders to /root/.config/subfinder/provider-config.yaml
[INF] Migration successful from /root/.config/subfinder/config.yaml to /root/.config/sub
finder/provider-config.yaml.

projectdiscovery.io

[INF] Current subfinder version v2.6.0 (outdated)
[INF] Loading provider config from /root/.config/subfinder/provider-config.yaml
[INF] Enumerating subdomains for itsecgames.com
itsecgames.com
www.itsecgames.com
[INF] Found 2 subdomains for itsecgames.com in 10 seconds 475 milliseconds

(root@kali)-[/home/raghav]
# amass enum -d itsecgames.com
itsecgames.com (FQDN) --> mx_record --> itsecgames-com.mail.protection.outlook.com (FQDN)
itsecgames.com (FQDN) --> ns_record --> ns53.domaincontrol.com (FQDN)
itsecgames.com (FQDN) --> ns_record --> ns54.domaincontrol.com (FQDN)
```

Fig11: Subdomain finder


```
root@kali: /home/raghav

[INF] Found 2 subdomains for itsecgames.com in 10 seconds 475 milliseconds

(root@kali)-[/home/raghav]
# amass enum -d itsecgames.com
itsecgames.com (FQDN) --> mx_record --> itsecgames-com.mail.protection.outlook.com (FQDN)
itsecgames.com (FQDN) --> ns_record --> ns53.domaincontrol.com (FQDN)
itsecgames.com (FQDN) --> ns_record --> ns54.domaincontrol.com (FQDN)
itsecgames.com (FQDN) --> a_record --> 31.3.96.40 (IPAddress)
ns54.domaincontrol.com (FQDN) --> a_record --> 173.201.74.27 (IPAddress)
ns54.domaincontrol.com (FQDN) --> aaaa_record --> 2603:5:22a2::1b (IPAddress)
www.itsecgames.com (FQDN) --> cname_record --> itsecgames.com (FQDN)
31.3.96.0/22 (Netblock) --> contains --> 31.3.96.40 (IPAddress)
173.201.64.0/20 (Netblock) --> contains --> 173.201.74.27 (IPAddress)
35470 (ASN) --> managed_by --> XL-AS (RIROrganization)
35470 (ASN) --> announces --> 31.3.96.0/22 (Netblock)
44273 (ASN) --> managed_by --> DYNAMICNET (RIROrganization)
44273 (ASN) --> announces --> 173.201.64.0/20 (Netblock)
2603:5:22a0::/44 (Netblock) --> contains --> 2603:5:22a2::1b (IPAddress)
44273 (ASN) --> managed_by --> GODADDY-DNS, DE (RIROrganization)
44273 (ASN) --> announces --> 2603:5:22a0::/44 (Netblock)
ns53.domaincontrol.com (FQDN) --> a_record --> 97.74.106.27 (IPAddress)
ns53.domaincontrol.com (FQDN) --> aaaa_record --> 2603:5:21a2::1b (IPAddress)
2603:5:2100::/40 (Netblock) --> contains --> 2603:5:21a2::1b (IPAddress)
44273 (ASN) --> announces --> 97.74.96.0/20 (Netblock)
44273 (ASN) --> announces --> 2603:5:2100::/40 (Netblock)

The enumeration has finished
```

Fig12: amass Enumeration

